Theoretical Knowledge

Incident Classification

Incident classification is an important process in cybersecurity operations that involves identifying and categorizing security incidents based on their nature and characteristics. Proper classification allows SOC analysts to understand the type of threat they are dealing with and determine the most appropriate response strategy. It also helps organizations maintain structured incident records and improve threat analysis and reporting.

Security incidents can be categorized into several common types. **Malware incidents** involve malicious software such as viruses, worms, trojans, ransomware, or spyware infecting systems. These incidents may result in system compromise, data theft, or unauthorized control of devices.

Another common category is **phishing attacks**, where attackers attempt to trick users into revealing sensitive information such as passwords or financial data through deceptive emails or websites. Phishing campaigns are often used as the initial access technique in many cyberattacks.

Distributed Denial-of-Service (DDoS) attacks are another category of incidents where attackers overwhelm systems or networks with excessive traffic in order to disrupt services. These attacks can cause major outages and impact business operations.

Insider threats involve malicious or negligent actions performed by individuals within the organization, such as employees or contractors. These incidents may include unauthorized access to confidential data, deliberate data theft, or misuse of company systems.

Another important category is **data exfiltration**, where attackers attempt to steal sensitive data from an organization's network. This may occur through compromised accounts, malware infections, or unauthorized data transfers to external systems.

To standardize the classification of security incidents, organizations often use structured frameworks and taxonomies. One widely used framework is the **MITRE ATT&CK framework**, which categorizes attacker behaviors into tactics and techniques. For example, phishing attacks are categorized under technique T1566 in the MITRE ATT&CK framework. By mapping incidents to these techniques, analysts can better understand how attackers operate and identify patterns across multiple incidents.

Other classification standards include the **ENISA Incident Taxonomy**, which provides structured categories for incident reporting, and the **VERIS framework (Vocabulary for Event Recording and Incident Sharing)**, which is used to document and analyze security incidents in a standardized way. These frameworks help organizations maintain consistent incident reporting and enable better data sharing between security teams and organizations.

Incident classification also involves collecting and attaching **contextual metadata** to each incident. This metadata may include information such as affected systems, timestamps of the

incident, source and destination IP addresses, malicious file hashes, and other indicators of compromise. This contextual information helps analysts perform deeper investigations and identify related incidents across different systems.

The primary objective of incident classification is to ensure that security events are categorized accurately and consistently. Proper classification improves investigation efficiency, supports threat intelligence analysis, and helps organizations identify trends in cyberattacks.

To learn incident classification techniques, analysts can explore the MITRE ATT&CK framework to understand attacker tactics and techniques. Studying the ENISA Incident Taxonomy and VERIS framework provides insight into structured incident reporting practices. Additionally, reviewing real-world case studies such as phishing campaigns documented in the SANS Reading Room can help analysts practice identifying incident categories and attaching relevant metadata.